

P8 — MITRE ATT&CK Threat Hunting Report

Structured Hypothesis-Driven Threat Hunting Engagement • Ref: HUNT-2026-P8-001

ENGAGEMENT REF

HUNT-2026-P8-001

PRIMARY SIEM

Splunk Enterprise 10.4.3

ENGAGEMENT LEAD

Natto Chakma

ENDPOINTS ANALYZED

WinServer2022 / ubuntu-p3

FRAMEWORK

MITRE ATT&CK v15 / TaHiTI

ADVERSARY NODE

Kali Linux (192.168.100.6)

ENGAGEMENT STATUS

COMPLETED & VALIDATED

ENGAGEMENT SCOPE

8 TACTICAL HUNT HYPOTHESES

TELEMETRY EVENTS ANALYZED

14,820

Sysmon XML, WinEvent, Linux logs

HYPOTHESES TESTED

8 / 8

Multi-source correlation

ATT&CK TACTICS MAPPED

8 Tactics

Initial Access to C2

DURABLE RULES ENGINEERED

4 Rules

Converted to permanent SIEM alerts

1. Executive Summary

In September 2026, the Security Operations Center (SOC) executed a proactive, hypothesis-driven threat hunting mission within the corporate infrastructure. Unlike traditional reactive alerts triggered by static signatures, this engagement operated under the assumption that advanced threat actors had achieved persistence or established undetected footholds using legitimate system binaries, stealth scripting wrappers, and Living-Off-The-Land (LOLBin) tradecraft.

The hunt tested 8 empirical hypotheses spanning Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Discovery, Lateral Movement, and Command & Control. Analyzing 14,820 events across Splunk Enterprise, the hunt successfully identified covert adversary techniques including Base64-obfuscated PowerShell download cradles, certutil.exe remote payload transfer, registry autostart persistence, and dynamic DNS querying.

2. Laboratory Topology & Monitored Telemetry Scope

Role	Hostname	IP Address	Operating System	Monitored Telemetry Channels
Central SIEM	wazuh-server	192.168.100.7	Ubuntu 24.04 LTS	Splunk Enterprise 10.4.3 (TCP 9997 forwarder receiver, Web UI port 18000)
Target Endpoint	WinServer2022 / Win 11	192.168.100.8	Windows Server 2022	index=sysmon (Sysmon v15.15 XML, EventIDs 1, 3, 11, 12, 13, 22), index=windows (Security, System)
Linux Server	ubuntu-p3	192.168.100.9	Ubuntu 24.04.5 LTS	index=linux_security (/var/log/auth.log, syslog, audit streams)
Adversary Node	kali	192.168.100.6	Kali Linux 2024.x	Controlled attack emulation and telemetry generation harness

3. Threat Hunting Methodology & Workflow

The hunt strictly adhered to the 8-stage hunting pipeline aligned with TaHiTI and PEAK methodologies: **Threat Hypothesis → MITRE ATT&CK Technique → Telemetry Identification → SPL Hunt Execution → Event Correlation → Forensic Investigation → Evidence Documentation → Conclusion & Hardening.**

4. Hypothesis Testing Results & Forensic Findings

#	Hunting Hypothesis	MITRE ATT&CK ID	Telemetry Evaluated	Outcome	Key Forensic Evidence
H1	Anomalous Logons & Pass-The-Hash	T1078, T1550.002	index=windows (4624, 4625, 4672)	CLEAN (BASELINE)	Observed standard Type 2 console & Type 4 batch authentications; no unauthorized Logon Type 9 (NewCredentials).
H2	LOLBin Ingress & Masquerading	T1218, T1105, T1036.005	index=sysmon (EventID 1)	THREAT IDENTIFIED	Execution of certutil.exe -urlcache -split -f staging files into %TEMP% directory.
H3	Obfuscated PowerShell Execution	T1059.001, T1027	index=sysmon (EventID 1)	THREAT IDENTIFIED	PowerShell launched with -ep bypass -w hidden -nop -enc VwByAGk... (Empirical Threat Score 70/100 confirmed).
H4	Endpoint Autostart Persistence	T1547.001, T1053.005	index=sysmon (1, 12, 13), index=windows (7045)	THREAT IDENTIFIED	Registry write under HKCU:\...\Run\P8_ThreatHunt_Persistence (EID 13) and schtasks /create /tn P8_ThreatHunt_Task (EID 1).
H5	Privilege Escalation & Sudo Abuse	T1098, T1548.003	index=windows (4728), index=linux_security	EMULATION CONFIRMED	Sudo permission checking (sudo -l) and administrative group auditing telemetry.
H6	Parent-Child Execution Anomalies	T1059.003, T1204.002	index=sysmon (EventID 1)	THREAT IDENTIFIED	Rapid discovery execution burst via cmd.exe /c whoami & whoami /priv & net user.
H7	Lateral Movement & Remote Access	T1021.001, T1021.002	index=windows (4624, 5140), index=sysmon	CLEAN (BASELINE)	Isolated administrative SMB sessions; no active PsExec (PSEXESVC.exe) lateral traversal.

#	Hunting Hypothesis	MITRE ATT&CK ID	Telemetry Evaluated	Outcome	Key Forensic Evidence
H8	C2 Dynamic DNS Beaconing	T1071.004, T1572	index=sysmon (EventID 22)	THREAT IDENTIFIED	Sysmon EventID 22 captured outbound resolution for beacon-p8-test.duckdns.org originating from powershell.exe.

5. Exemplary Threat Hunting SPL Logic

```
# Detects Obfuscated PowerShell Execution (T1059.001 / T1027)
index=sysmon earliest=-7d
| rex field=_raw "<EventID>(?(EventID\d+)</EventID>"
| search EventID=1
| rex field=_raw "<Data Name='Image'>(?(Image>[^<]+)</Data>"
| rex field=_raw "<Data Name='CommandLine'>(?(CommandLine>[^<]*)</Data>"
| search Image="*\\powershell.exe" OR Image="*\\pwsh.exe"
| eval cmd_lower=lower(CommandLine)
| eval has_enc=if(match(cmd_lower, "(?i)\\s+(e|en|enc|encodedcommand)\\s+"), 30, 0)
| eval has_bypass=if(match(cmd_lower, "(?i)\\s+(ep|executionpolicy)\\s+bypass"), 20, 0)
| eval has_hidden=if(match(cmd_lower, "(?i)\\s+(w|windowstyle)\\s+hidden"), 20, 0)
| eval has_cradle=if(match(cmd_lower, "(?i)(downloadstring|downloaddata|net\\.webclient|invoke-webrequest|iwr)"), 25, 0)
| eval threat_score=has_enc+has_bypass+has_hidden+has_cradle
| where threat_score>=40
| table _time, threat_score, CommandLine, Image
```

6. Strategic Remediation & Hardening Recommendations

- Operationalize Permanent Correlation Searches:** Convert hunting queries for LOLBins (certutil/mshta) and Obfuscated PowerShell into real-time Splunk scheduled alerts.
- Application Control & Constrained Language Mode (CLM):** Restrict PowerShell execution policy via Group Policy and enforce Constrained Language Mode to block dynamic code injection.
- Egress Firewalling for LOLBins:** Block Windows system binaries such as certutil.exe and bitsadmin.exe from initiating outbound internet connections directly at the host firewall level.
- DNS Sinkholing:** Configure DNS filtering on corporate resolvers to immediately sinkhole queries resolving to dynamic DNS domains (e.g. duckdns.org, ngrok.io).